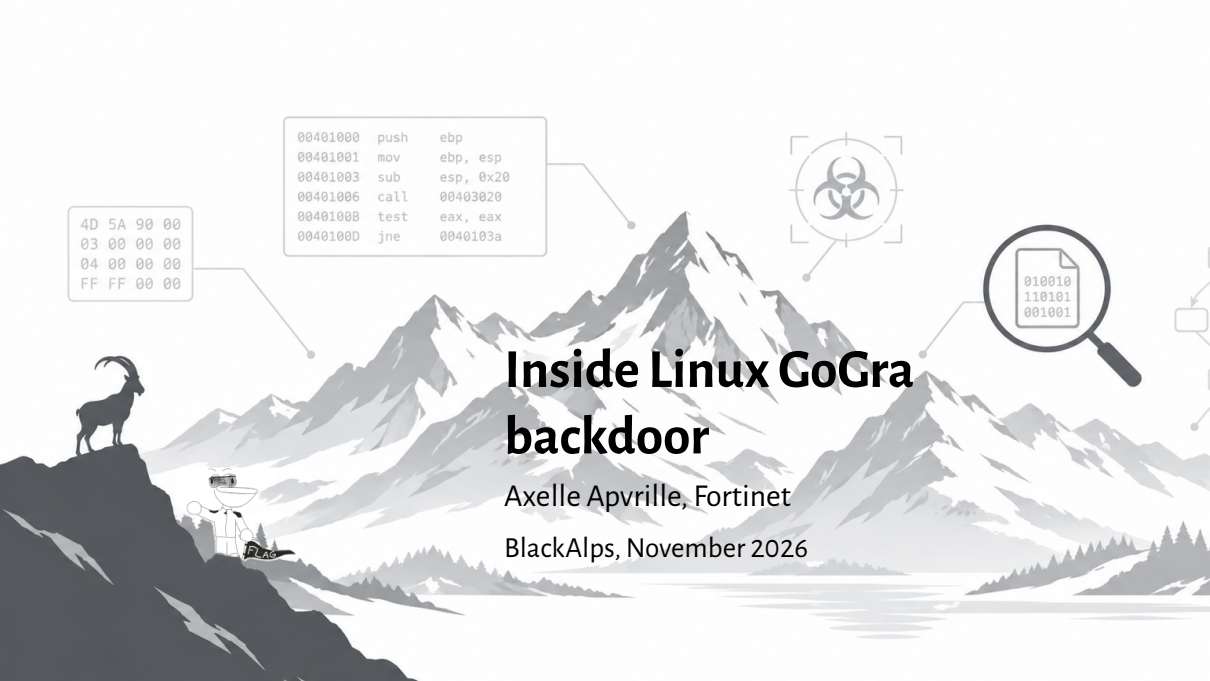
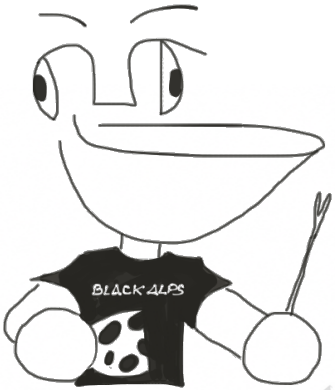


Inside Linux GoGra backdoor

Axelle Apvrille, Fortinet

BlackAlps, November 2026

Who am I?



- Principal security researcher with **Fortinet**
- Reverse incoming **mobile malware** (Android, iOS) and **IoT malware**
- Founder of Ph0wn CTF

© Fortinet Inc. All Rights Reserved

Agenda

1. Who am I
2. GoGra malware analysis
   - **GoGra: chronology, delivery and attack chain**
   - GoGra: details of the Dropper's mechanism
3. The journey is as important
   - Reversing Go binaries
   - Go Strings
   - Go PCLNTAB
   - Human-AI cooperation: C2 communication encryption
4. Conclusion

© Fortinet Inc. All Rights Reserved

GoGra

- **Backdoor** family,
- Targets mostly **South Asia, India and Afghanistan**,
- Attributed by Symantec to APT group *Harvester*. Nation-state backed. Targeting telecom, IT and **government** sectors.
- Symantec, Harvester: APT Group Expands Toolset With New GoGra Linux Backdoor 🔗

IOC:

9c23c65a8a392a3fd885496a5ff2004252f1ad4388814b20e5459695280b0b82



All images of Pico le Croco 🔗 are hand made by myself 😊

© Fortinet Inc. All Rights Reserved.

Chronology

June 2021 — Graphon

Nov 2023 — GoGra Windows

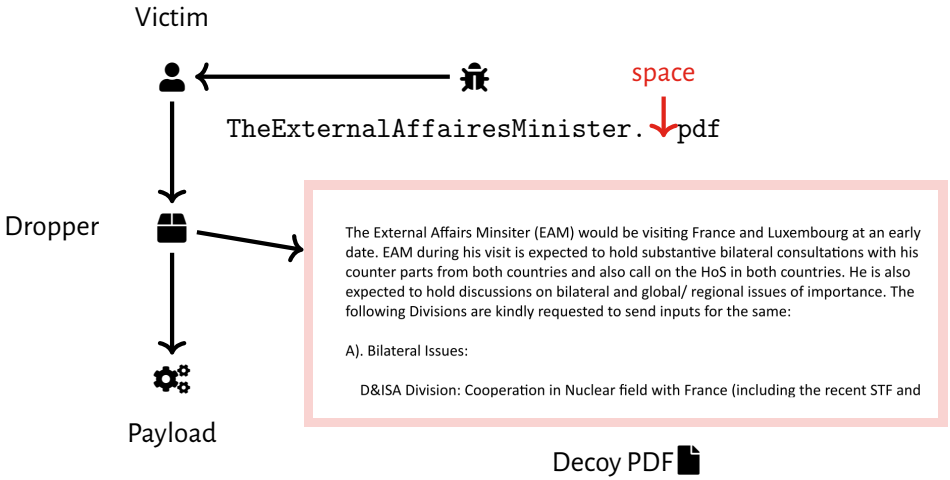
April 2026 — GoGra Linux

- **Graphon** is an *ancestor*: .NET backdoor.
- Both attributed to **Harvestor** APT group



© Fortinet Inc. All Rights Reserved

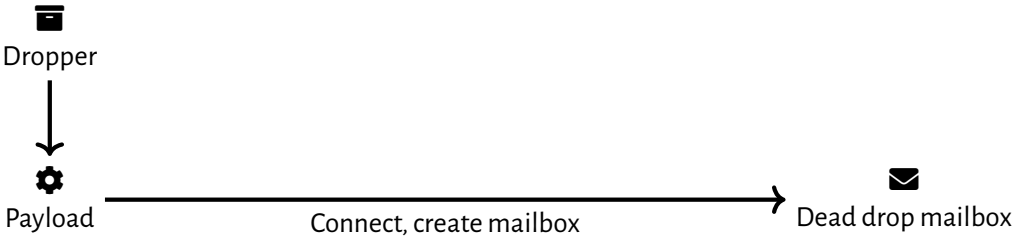
GoGra delivery chain



© Fortinet Inc. All Rights Reserved.

GoGra attack chain

- **Go-**. Implemented in **Go**,
- **Gra**.Abuses Microsoft **Gra**ph API: REST API to access an Outlook mailbox.

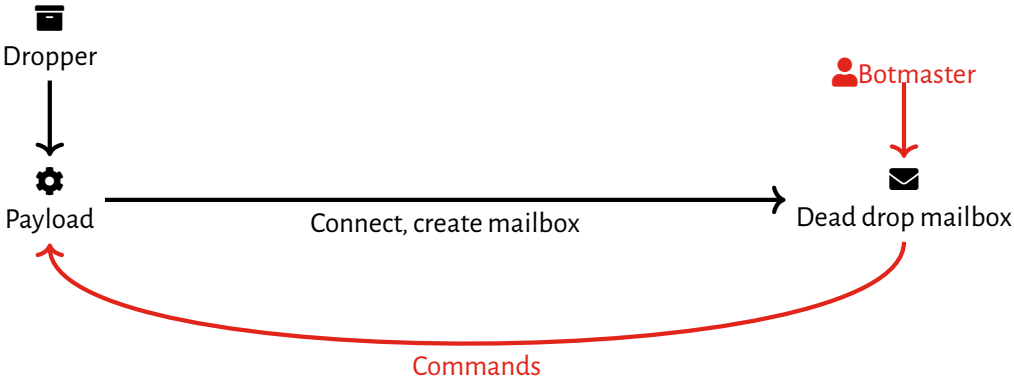




© Fortinet Inc. All Rights Reserved.

GoGra attack chain

- **Go-**. Implemented in **Go**,
- **Gra**.Abuses Microsoft **Gra**ph API: REST API to access an Outlook mailbox.





© Fortinet Inc. All Rights Reserved.

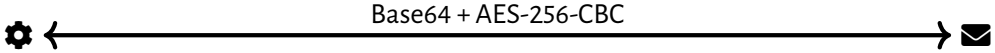
By the way, this is quite smart



1. Communication occurs through a **legitimate protocol**.
2. The **botmaster can change over time**. Bots don't know who is their master.
3. OAuth2 token not as easy to trace as an email address.

© Fortinet Inc. All Rights Reserved

Communication with C2 is encrypted




```
ciphertext, err := base64.StdEncoding.DecodeString(encrypted)
block, err :=
 ↪  aes.NewCipher([]byte("b14ca5898a4e4133bbce2ea2315a1916"))

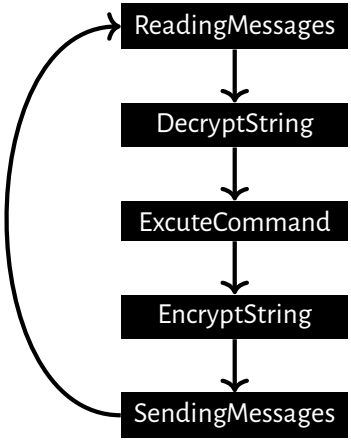
// zero IV: the 16-byte buffer is never populated
iv := make([]byte, aes.BlockSize)
mode := cipher.NewCBCDecrypter(block, iv)

plaintext := make([]byte, len(ciphertext))
mode.CryptBlocks(plaintext, ciphertext)

padding := int(plaintext[len(plaintext)-1])
return string(plaintext[:len(plaintext)-padding]), nil
```


© Fortinet Inc. All Rights Reserved.

Main loop: encrypting/decrypting C2 emails



AES-256-CBC with hardcoded key

Typo as in code



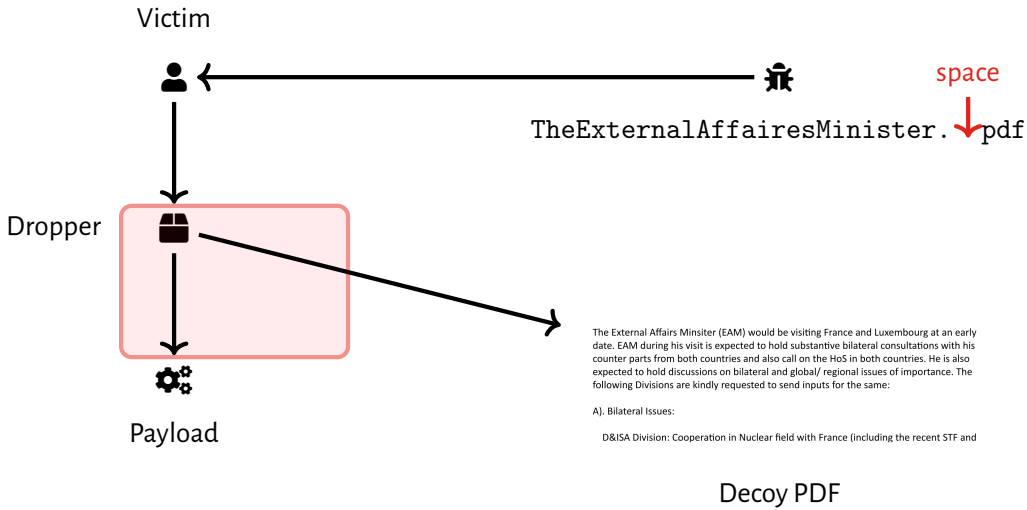
© Fortinet Inc. All Rights Reserved.

Agenda

1. Who am I
2. GoGra malware analysis
   - GoGra: chronology, delivery and attack chain
   - **GoGra: details of the Dropper's mechanism**
3. The journey is as important
   - Reversing Go binaries
   - Go Strings
   - Go PCLNTAB
   - Human-AI cooperation: C2 communication encryption
4. Conclusion

© Fortinet Inc. All Rights Reserved.

Details of the Dropper's Extraction mechanism



© Fortinet Inc. All Rights Reserved.

Embedding files in Go

go : embed to include static files and directories

```
import _ "embed"

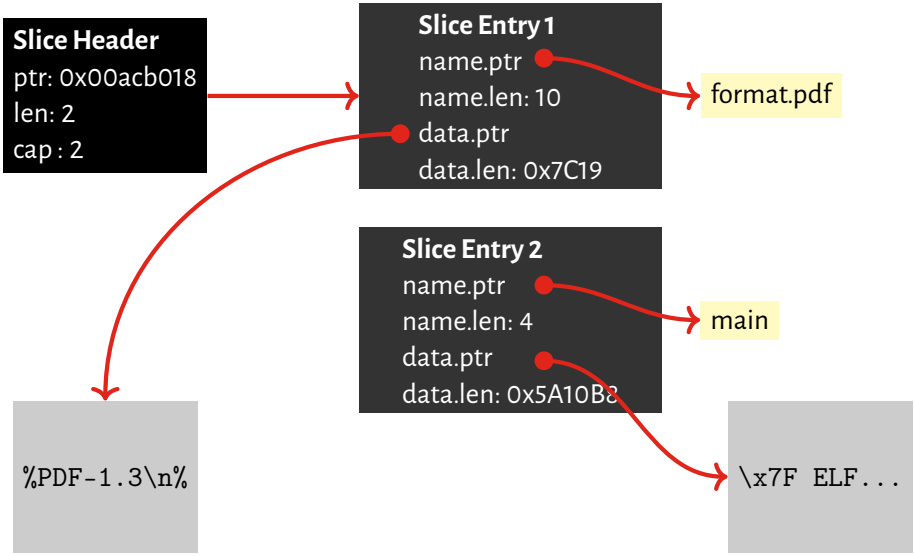
//go:embed main
//go:embed format.pdf
var embeddedFS embed.FS
```

- `//go:embed` is a **compiler directive comment**.
- It is binded to the *next* line, `embed.FS`.
- It reads `main` and `format.pdf` at compile time.



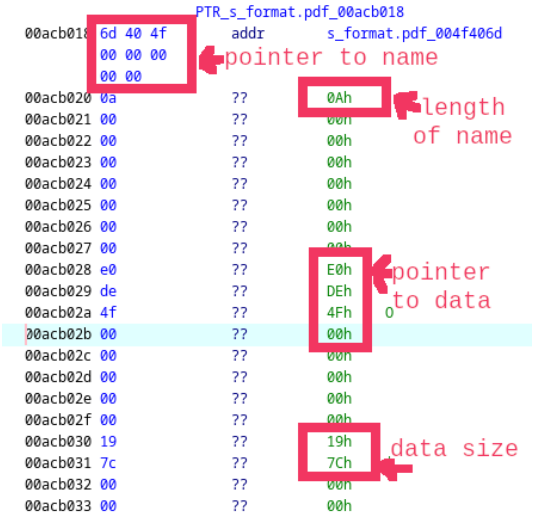
© Fortinet Inc. All Rights Reserved.

At binary level



© Fortinet Inc. All Rights Reserved.

Example of Slice Entry



Screenshot of Ghidra showing the slice entry for `format.pdf` file.

© Fortinet Inc. All Rights Reserved.

Let's script it



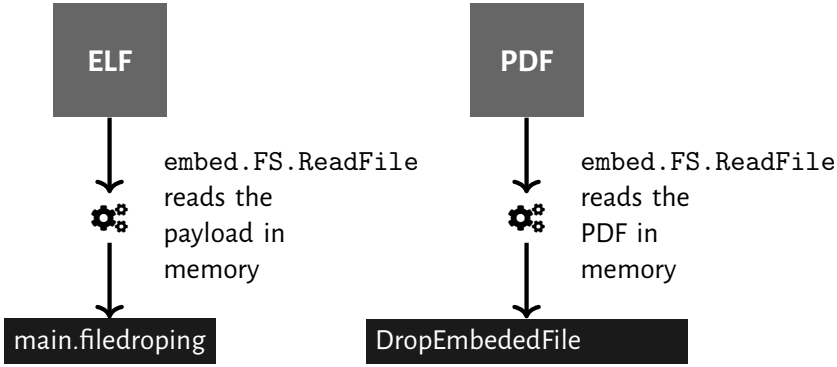
⟵ *with AI (shhhhh)*

```
ExtractPayload.java> Running...
[*] ExtractPayload: embed.FS at VA 0xb6ee20
[*] embed.FS.files ptr = 0xacb000
[*] File table: data=0xacb018  len=2  cap=2
[*] Entry 0: name='format.pdf'  data=0x4fdee0  size=31769
↪   hash=e8114d6a18220998a1546cbbd633ce52
    [*] Read 31769 / 31769 bytes from VA 0x4fdee0
    [+] Written to: ./artifacts/format.pdf
    [+] File type: PDF
[*] Entry 1: name='main'  data=0x505b00  size=5902520
↪   hash=e2f8b227e8b1046921acfd15acd06f32
    [*] Read 5902520 / 5902520 bytes from VA 0x505b00
    [+] Written to: ./artifacts/main
    [+] File type: ELF executable

[*] Done.
ExtractPayload.java> Finished!
```


© Fortinet Inc. All Rights Reserved.

Executing the payload



© Fortinet Inc. All Rights Reserved.

The results matter, but the journey is just as important



How do we reverse a Go binary?
Does AI help (or is it bad for your mental health)?

Static analysis is difficult

- It requires **patience** and **skills**.
- More and more malware analysts use **dynamic analysis**. It's more *rewarding*.
- **Attackers took control** of G-Data researchers VM. Read about it at Virus Bulletin 2026 🔗.



© Fortinet Inc. All Rights Reserved.

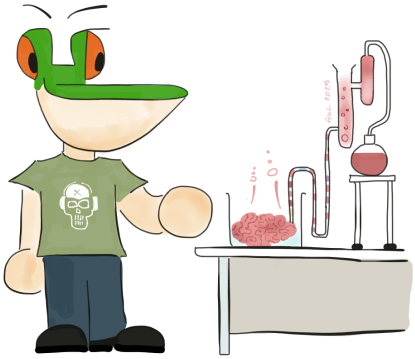
Reversing Go is particularly difficult



- Decompilers don't handle Go **strings** correctly.
- Go uses a **stack-based ABI** on i386. This confuses **Ghidra**.
- Binaries are **stripped**. Some information is recoverable in the `.gopclntab`, but Ghidra doesn't know how to do that (by default).
- Reversing Go: Asher Davila, 2026

© Fortinet Inc. All Rights Reserved.

Solution?



Static Analysis assisted by AI

- **AI** will fix specific Go decompiler issues … and the **decompiler** will fix AI issues ☻
- **Open your decompiler. AI is not magic.**

© Fortinet Inc. All Rights Reserved.

AI Setup

AI harness



Ghidra MCP

MCP

Ghidra



“Locate the main loop”

ghidra_list_open_programs

ghidra_search_functions

ghidra_decompile_function

© Fortinet Inc. All Rights Reserved.

Agenda

1. Who am I
2. GoGra malware analysis
   - GoGra: chronology, delivery and attack chain
   - GoGra: details of the Dropper's mechanism
3. The journey is as important
   - Reversing Go binaries
   - **Go Strings**
   - Go PCLNTAB
   - Human-AI cooperation: C2 communication encryption
4. Conclusion

© Fortinet Inc. All Rights Reserved

Go Strings




```
082858d8 MOV dword ptr [ESP + 0x54]=>Stack[0xc],EAX=>scmd // pointer
082858dc MOV dword ptr [ESP + 0x58]=>Stack[0x10],0x12     // length
```

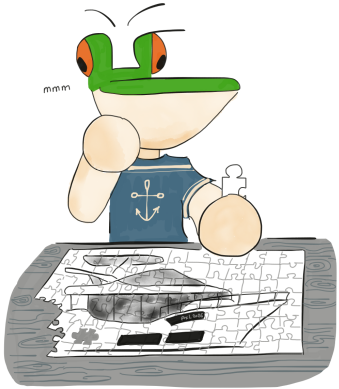
- Go strings consist in a **pointer** and a **length**.
- They are not `null`-terminated.

© Fortinet Inc. All Rights Reserved.

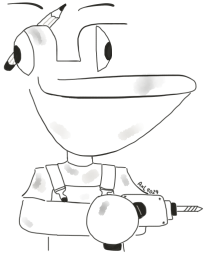
How Ghidra displays Go Strings

```
scmd = "command length : 0client_credentialsreflect.Value.Uintcannot
↪   be negativevalue out of range298023223876953125: day out of
↪   rangeTime.MarshalJSON: Time.MarshalText: unknown time zone http:
↪   blank cookiereceived from peer...
```

- They are grouped in a **string pool** for optimization reasons.
- Ghidra doesn't know where the string ends...



Surely, there's a script for that!

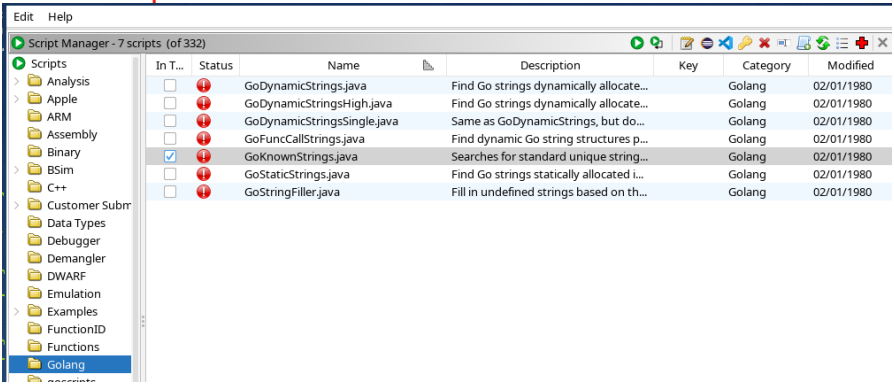


Ghostrings 🔗: collection of scripts for Ghidra

1. Learn how to use it
2. Clear all incorrect or automatically defined strings
3. Run GoKnownStrings.java
4. Run GoStaticStrings.java
5. ...

© Fortinet Inc. All Rights Reserved.

Surely, there's a script for that! Yes … but no.



Console errors

```
symbol:   variable GhostringsUtil
location: class GoDynamicStrings.GoStringDecompConsumer
GoDynamicStrings.java:165: error: cannot find symbol
  printf("Decompilation not completed for %s\n", GhostringsUtil.funcNameAndAddr(func));
```


© Fortinet Inc. All Rights Reserved.

Go Strings: Solutions



1. Fix the compilation errors. Hopefully not too difficult.
2. Find another plugin. GoStringExtractor helps, but not exactly what we want.
3. Ask AI to do it.

© Fortinet Inc. All Rights Reserved.

Movie Time


What a great tech talk !
Next year, don't forget the POP CORN !
Graph API
Golang
Malware
Ghidra

Agenda

1. Who am I
2. GoGra malware analysis
   - GoGra: chronology, delivery and attack chain
   - GoGra: details of the Dropper's mechanism
3. The journey is as important
   - Reversing Go binaries
   - Go Strings
   - **Go PCLNTAB**
   - Human-AI cooperation: C2 communication encryption
4. Conclusion

© Fortinet Inc. All Rights Reserved

Ghidra offers no function names




```
file ./gogra.elf
  ./gogra.elf: ELF 64-bit LSB executable, x86-64 ..
  ↪  stripped
```

- **Stripped** ELF: symbols are gone.
- But the binary obviously includes some **function names**:

```
$ strings ./gogra.elf | grep main
main.main
main.filedroping
main.creatingDesktopfile
main.CreateServiceFile
main.DropEmbededFile
main.OpenFile
```


© Fortinet Inc. All Rights Reserved.

Function metadata

- **Go** stores **function metadata** in a special tab: pclntab (since 2014)
- Pclntab source code
- Ghidra doesn't know how to parse it, but researchers do

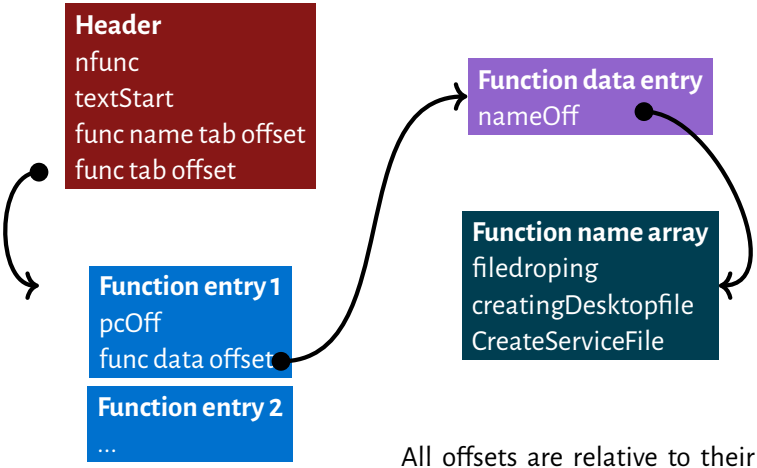


© Fortinet Inc. All Rights Reserved



Hang on!
It gets *slightly* technical.
But it's not that difficult.

© Fortinet Inc. All Rights Reserved.



PC-LN-TAB is in the .gopclntab section

All offsets are relative to their start of their own tab
Except `pcOff` is relative to `textStart`

© Fortinet Inc. All Rights Reserved.

Asking AI to rename functions

Read this https://cujo.com/blog/reverse-engineering-go-binaries-with-ghidra/ to understand how to find the function.

Step 1

tell AI to read blog

% WebFetch https://cujo.com/blog/reverse-engineering-go-binaries-with-ghidra/

The article describes the pclntab structure: each functab entry is {function_entry_PC, offset_to_function_metadata}, and the function metadata contains an offset to the function name. So I need to:

1. Find the functab in .gopclntab
2. Walk entries until the name offset points to ReadingMessages

The .gopclntab starts at 0x08410ec0. From the header: pfunc=0x188C. The functab starts after the header+offsets. Let me read the functab area and find the entry whose name offset resolves to ReadingMessages.

Step 2

AI finds gopclntab

AI Python script to find the PCLNTAB entry for `ReadingMessages`

header+offsets. Let me read the functab area and find the entry whose name offset resolves to ReadingMessages.

```
$ python3 -c "
import struct

# From binary: .gopclntab = 0x08410ec0
# Header bytes (from Ghidra inspect):
# F1 FF FF FF 00 00 01 04 8C 18 00 00 A6 02 00 00
# 00 90 04 08 40 00 00 00 E0 BC 04 00 00 FA 04 00
# 00 73 05 00 E0 24 11 00 ...

# magic=0xFFFFFFF1 (Go1.20), minLC=0, quantum=0, ptrSize=4 (32-bit)
# nfunc = 0x188C = 6284
# After header (16 bytes) come 8 pointer-sized table VA/offset entries

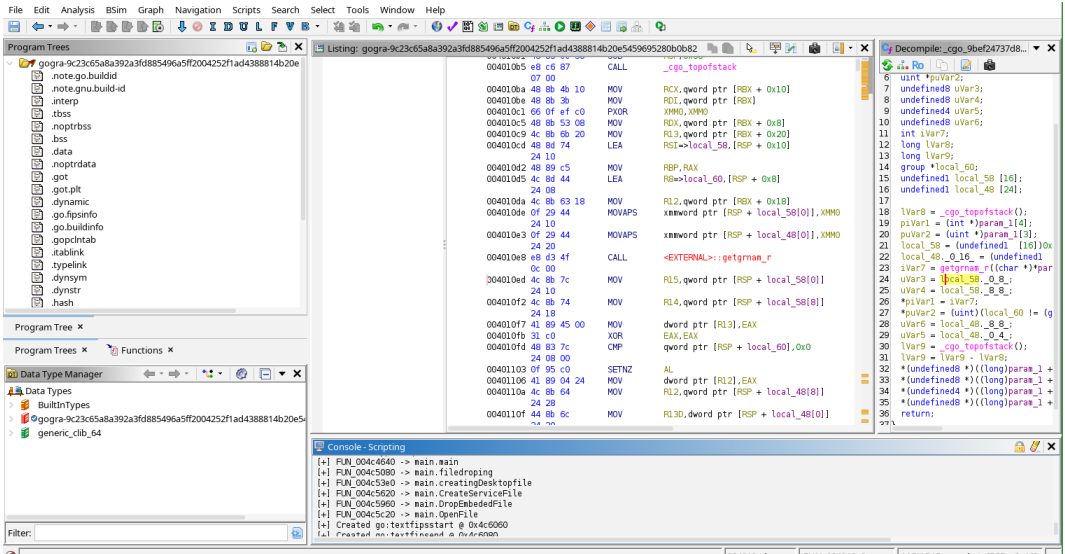
# From the hex dump at offset +0x10:
# 00 90 04 08 -> LE = 0x08049000  -- looks like an absolute VA
# 40 00 00 00 -> 0x00000040       -- relative offset 0x40 from pclntab base
# E0 BC 04 00 -> 0x0004BCE0
# 00 FA 04 00 -> 0x0004FA00
# 00 73 05 00 -> 0x00057300
# E0 24 11 00 -> 0x001124E0

# In Go 1.20 pclntab these 8 entries are all relative offsets from pclntab start:
```



© Fortinet Inc. All Rights Reserved.

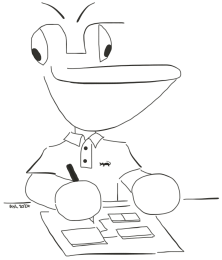
AI script for Ghidra



© Fortinet Inc. All Rights Reserved.

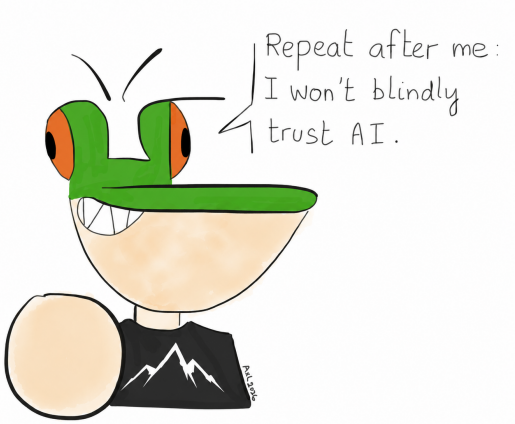
AI script for Ghidra

```
[+] os/user.Current.func1 -> os/user.Current.func1
[+] type:.eq.os/user.User -> type:.eq.os/user.User
[+] main.main -> main.main
[+] main.filedroping -> main.filedroping
[+] main.creatingDesktopfile -> main.creatingDesktopfile
[+] main.CreateServiceFile -> main.CreateServiceFile
[+] main.DropEmbededFile -> main.DropEmbededFile
[+] main.OpenFile -> main.OpenFile
```



© Fortinet Inc. All Rights Reserved.

Fact: AI makes errors



- AI thought the malware was **executing the PDF**. **Wrong**.
- AI confuses a **Go Build Id** with a **Graph API Bearer Token**. **Face palm**.

© Fortinet Inc. All Rights Reserved.

Fact: Decompilers make error too!

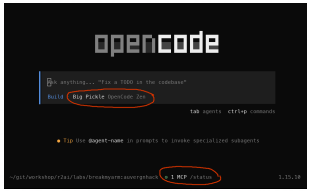
```
OUTLOOKCLIENT/services.GetCompleteAuth(local_54,local_50,&DAT_0838c158,0xc
FUN_080c9590();
// main processing loop
do {
  // read incoming messages
  OUTLOOKCLIENT/services.ReadingMessages(local_30,local_2c);
  // what? nothing else?????
  time.Sleep(2000000000,0);
} while( true );
```

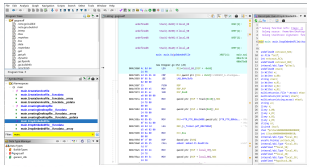
Reason: Wrong ABI for ReadingMessages leads to skipping lots of assembly lines

© Fortinet Inc. All Rights Reserved.

AI is not all Good or all Bad

When AI claims something, **check it** with your own eyes in Ghidra's assembly





When assembly is difficult to understand, **ask AI** to clarify, create scripts, comments

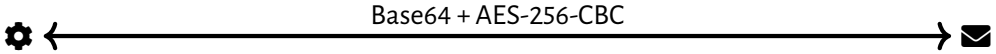
© Fortinet Inc. All Rights Reserved

Agenda

1. Who am I
2. GoGra malware analysis
   - GoGra: chronology, delivery and attack chain
   - GoGra: details of the Dropper's mechanism
3. The journey is as important
   - Reversing Go binaries
   - Go Strings
   - Go PCLNTAB
   - **Human-AI cooperation: C2 communication encryption**
4. Conclusion

© Fortinet Inc. All Rights Reserved.

Communication with C2 is encrypted: cooperation between Malware Analyst and AI



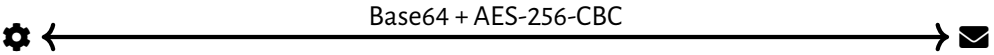

```
ciphertext, err := base64.StdEncoding.DecodeString(encrypted)
block, err :=
↪   aes.NewCipher([]byte("b14ca5898a4e4133bbce2ea2315a1916"))

// zero IV: the 16-byte buffer is never populated
iv := make([]byte, aes.BlockSize)
mode := cipher.NewCBCDecrypter(block, iv)
```

How did we find out communication is encrypted?

© Fortinet Inc. All Rights Reserved.

What LLM says about C2 communication encryption



- LLM says each incoming email is **“likely AES-encrypted in the body”**.
- But, it is unable to find the proof:

```
To directly answer your question: no, we don't have proof that the body is
encrypted — we have proof that AES-256-CBC capability exists in the binary
and is named for C2 use, but static analysis never found a caller of
services_DecryptString, so the call chain from "receive email → decrypt
body" was not traced. The "no callers" finding is the gap. The update
reflects this accurately rather than overclaiming.
```



© Fortinet Inc. All Rights Reserved.

Are emails encrypted or not? Let's investigate



1. LLM clearly identified the AES functions, but **is unable to trace them back to communication with Graph API**
   crypto/aes.NewCipher, crypto/cipher.NewCBCDecrypter...
2. Emails are handled by:

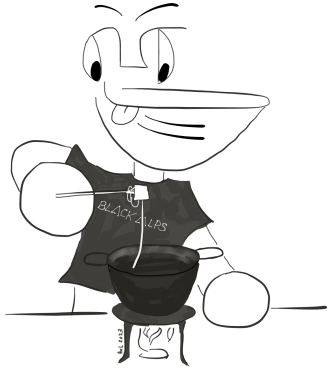
Address	Malware function name
0x08286660	OUTLOOKCLIENT/services.ReadingMessages
0x082870e0	OUTLOOKCLIENT/services.SendingMessages

3. But AES is **not** used in ReadingMessages or SendingMessages.

© Fortinet Inc. All Rights Reserved.

Pivoting via human intuition

1. `ReadingMessages` returns a **message body**.
2. Perhaps that body is *still encrypted*, and **decryption occurs after**
3. What happens **after** `ReadingMessages`? Who calls `ReadingMessages`?



Fondue or raclette is an excellent source of intuition

© Fortinet Inc. All Rights Reserved.

LLM was looping helplessly. This unlocks the situation.

> Where does the implant process the content of the email?

Good question. The call chain we need to trace is: `ReadingMessages` returns `msg.Body.Content` → something receives it → processes/decrypts/executes it. Let me find that caller.

⚙ ghidra_get_function_callers [address=0x08286660]
⚙ ghidra_get_function_xrefs [address=0x08286660]

1. It identifies the caller of `ReadingMessages`.
2. Sees that `DecryptString` is called just after.
3. Conclusion: Emails are AES-encrypted. We have the proof.



© Fortinet Inc. All Rights Reserved.

Agenda

1. Who am I
2. GoGra malware analysis
   - GoGra: chronology, delivery and attack chain
   - GoGra: details of the Dropper's mechanism
3. The journey is as important
   - Reversing Go binaries
   - Go Strings
   - Go PCLNTAB
   - Human-AI cooperation: C2 communication encryption
4. **Conclusion**

© Fortinet Inc. All Rights Reserved

Good news

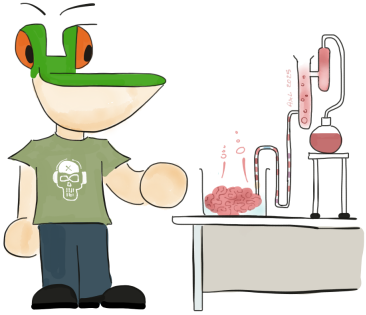


Well maybe not *easy*, but *easier*

- Cybercriminals use **Go, Rust, Dart** because they are difficult to reverse.
- Decompilers have difficulties processing those languages: specific ABI, specific registers etc.
- **With AI's assistance**, this is far easier.

© Fortinet Inc. All Rights Reserved.

Tips



- Open your disassembler **first**, or you're doing it wrong.
- The key 🔑 is **drive AI**, not the opposite!
- There are **MCPs** for all (?) disassemblers: Radare2, IDA Pro, JEB…
- I like OpenCode, but you can use whatever: Claude Code, VS Code, Warp…
- **Skills**: after 1 year+ of experience, *I don't find them so useful for malware analysis*. Bloat context size for little added value.
- **Orchestration agent** for malware analysis: will improve. Reversing works for details.
  Asking general questions answers gives higher chances for hallucinations

© Fortinet Inc. All Rights Reserved.

Thanks for your attention



Questions?

- Contact: Cryptax on Mastodon, BlueSky, Discord, `aapvrille@fortinet.com`
- https://fortinet.com/blog/threat-research
- *Malware GoGra: quand l'IA et votre désassembleur se liguent contre vous*, MISC no. 148, in French.
- GoGra Linux Dropper analysis (tomorrow)
- GoGra Linux Payload analysis (tomorrow)

© Fortinet Inc. All Rights Reserved

I thought it was **50**-minute slots, not **30**
A few more slides if you care to read them.



© Fortinet Inc. All Rights Reserved

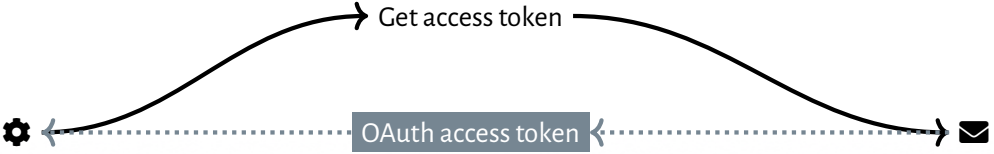
Different campaigns, different decoy PDFs, different details

Sample	Variant	C2 Folder	Decoy PDF name	Targeted region
d728cdcf6...	Windows (2024)	Dragan Dash	-	South Asia
9c23c65a8...	Linux (2026)	Zomato Pizza	format.pdf	India
57cd5721b...	Linux (2026)	Zomato Pizza	TheExternal-AffairesMinister.pdf	India
d8d84eaba...	Linux (2026)	Zomato Pizza	Details Format.pdf	India / Afghanistan



© Fortinet Inc. All Rights Reserved

Step 1: Logging in the application



POST `login.microsoftonline.com/HARDCODED-TENANT-ID/oauth2/token`

Parameters

`client_id`: hardcoded

`client_secret`: hardcoded

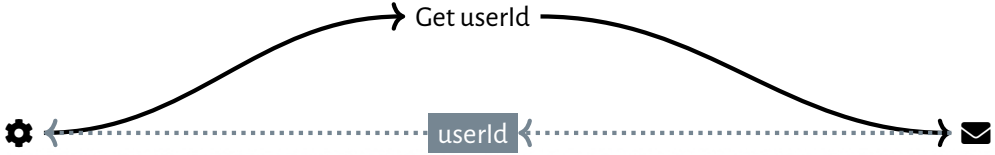
`grant_type=client_credentials`

Response:

`access_token`

© Fortinet Inc. All Rights Reserved

Step 2: Getting the userId



GET /beta/users

Query parameters:
$select=id$filter=startswith(displayname, 'Zomato Pizza')

Header
Authorization:
Bearer accessToken

Response:
userId

© Fortinet Inc. All Rights Reserved

Step 3: Create folder for infected bot



POST `/beta/users/{userId}/mailFolders`

JSON body

```
{"displayName":  "<username>-<pid>-Linux"}
```

Header

```
Authorization:
Bearer accessToken
```

Response:

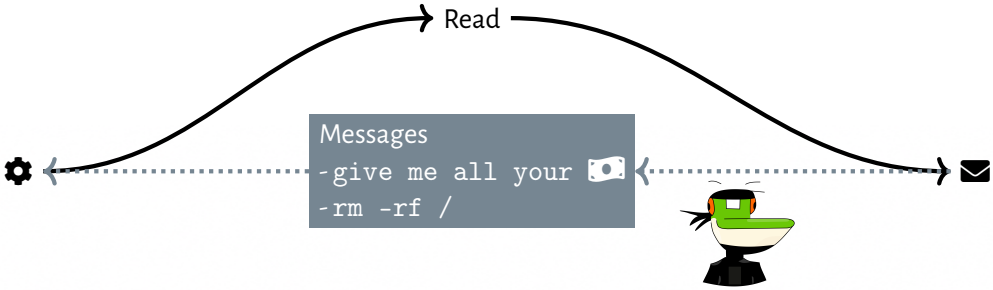
```
folderId
```

root-123-Linux
blah-22929-Linux
pico-12923-Linux
alps-86287-Linux



© Fortinet Inc. All Rights Reserved

Step 4: Read E-Mail Messages



GET /beta/users/{userId}/mailFolders/{folderId}/messages
?$filter=startswith(subject,'Input')

Header
Authorization:
Bearer accessToken

© Fortinet Inc. All Rights Reserved

Microsoft Graph API abuses

- The tenant is *not necessarily the attacker*. Possibly a *compromised* account.
- The attacker registered an **Entra ID application** (Azure AD).
- **Application is now revoked** `AADSTS5000224: We are sorry, this resource is not available.`

Malware	Year	Attribution	Abuse
Bluelight	2021	North Korea	Create subdirectory in OneDrive appfolder
Graphon	2021	Harvester	
Graphite	2022	APT28 (?)	OneDrive
SiestaGraph	2022	?	OneDrive and Microsoft 365 Mail
Graphican	2023	Flea APT15	
CMD365	2025	WIP26	
HollowGraph	2026	Iran	Calendar events

© Fortinet Inc. All Rights Reserved



It's a **Linux** malware, and I end up reversing **Microsoft** stuff?! How charming.

© Fortinet Inc. All Rights Reserved